

Contents

1	権限設計書 (メイン)	1
1.1	1. 文書概要	1
1.1.1	1.1 目的	1
1.1.2	1.2 対象範囲	1
1.1.3	1.3 版数	1
1.1.4	1.4 関連ドキュメント	1
1.2	2. ロール一覧	2
1.3	3. ロール定義 (project_users.role 2 値 + オーナー)	2
1.3.1	3.1 ロール概要	2
1.3.2	3.2 ロール × 主管 SCR / FR 対応	2
1.3.3	3.3 オーナー専有機能 (プロジェクト別ロールでは付与不可)	3
1.4	4. 画面別権限マトリクス	3
1.5	5. 機能別権限	5
1.6	6. API 別権限	5
1.7	7. 契約別利用制限 / 運営者上書き	6
1.7.1	7.1 単一プランの利用上限 (11_課金請求設計書.md § 3 参照)	6
1.7.2	7.2 80/100/125% 三段階アクション (11_課金請求設計書.md § 8 の参照)	6
1.8	8. 権限不足・契約上書き時の動作	7
1.9	9. 緊急時のみ可操作 (§ 3.2.1-2 から移管)	7
1.9.1	9.1 「△ 緊急時のみ可」操作の発動条件	7
1.9.2	9.2 緊急区分 × 検知ハンドラ × 承認 SLA	7
1.10	10. 未決事項	8

1 権限設計書 (メイン)

1.1 1. 文書概要

1.1.1 1.1 目的

メインシステムの権限モデル (オーナー / プロジェクト管理者 / メンバー / エンドユーザー / 運営者)、プロジェクト別ロール 2 値、画面別・機能別・API 別の操作可否、**契約別利用上書き** を一元化する。

1.1.2 1.2 対象範囲

- 対象: 利用者側の操作者種別 (管理者 = **users** テーブル / エンドユーザー = **end_users** テーブル。運営者は別 D1 の **service_operators** テーブルで管理し、メイン側 **users** には格納しない)、プロジェクト別ロール (**project_users.role** = **admin** / **member**)、オーナー専有機能 (**contract_owners** 行存在で判定)、契約別利用上書き
- 対象外: 運営者ロール (02_運営者システム/個別設計書群/05_権限設計書.md 参照)、認証フロー (09_認証認可設計書.md 参照)

1.1.3 1.3 版数

項目	値
版数	1.2
更新日	2026-05-19

1.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_索引.md
認証・認可設計書	認可判定ロジック / Principal	09_認証認可設計書.md
画面設計書	画面別表示制御	02_画面設計書.md
API 設計書	API 別権限	03_API 設計書.md
課金・請求設計書	契約別利用上書き (owner_quota_overrides 等)	11_課金請求設計書.md
エラー設計書	権限不足時のエラー	06_エラー設計書.md

ドキュメント名	役割	参照先
テーブル定義書	project_users.role(プロジェクト別ロール 2 値)	04_テーブル定義書.md

1.2 2. ロール一覧

利用者側は 3 つのロール (オーナー / プロジェクト管理者 / メンバー) で構成する。プロジェクト管理者とメンバーは「プロジェクト単位」のロールであり、同一メンバーがプロジェクト A では **admin**、プロジェクト B では **member**、プロジェクト C には未割当、といった組合せをとり得る。

ロール ID	表示名	説明文 (UI)	DB 値
OWNER	契約オーナー	契約全体を管理し、プロジェクト作成・課金・退会などすべての設定を操作できます。	users 行存在 AND contract_owners.user_id = users.id 行存在
PROJECT_ADMIN	プロジェクト管理者	担当プロジェクトの FAQ、問い合わせ対応、メンバー招待・ロール変更を行えます。	users 行存在 AND contract_owners 行を持たない AND project_users.role='admin'(プロジェクト単位)
MEMBER	プロジェクトメンバー	担当プロジェクトの FAQ や問い合わせを確認・対応できます。	users 行存在 AND contract_owners 行を持たない AND project_users.role='member'(プロジェクト単位)
END_USER	チャット利用者	ウィジェットから個別チャットを開始し、履歴確認・投稿ができます。	end_users 行存在 (プロジェクト単位識別)
SERVICE_OPERATOR	サービス提供者	サービス提供者として、サポートや障害対応に必要な運用操作を行えます。	別 D1(運営者システム service_operators テーブル)——メイン側 users には格納しない。メイン API への運営者アクセスは IF 経由の認可コンテキストで実現し、audit_logs.actor_role='service_operator' の値として記録する

用語の衝突回避: 管理者の認証主体は **users** テーブル (全行が管理者) で、エンドユーザーは独立テーブル **end_users** で管理される。**project_users.role='admin'** はプロジェクト管理者ロールを示し、**users** テーブルのロール概念とは別軸。**audit_logs.actor_role** は操作者種別 (**admin** / **end_user** / **system** / **service_operator**) を記録するもので、**users** のロール定義とは独立した概念 (§ 03_テーブル設計.md § 3.23 参照)。

1.3 3. ロール定義 (project_users.role 2 値 + オーナー)

1.3.1 3.1 ロール概要

ロール	表示名 (UI)	範囲	できること
オーナー	契約オーナー	契約全体	すべてのプロジェクトと契約設定を管理できます。プロジェクト作成・課金・退会・規約同意・メンバー管理も行えます。
admin	プロジェクト管理者	該当プロジェクト	担当プロジェクトの FAQ 公開、問い合わせ対応、ログ確認、データ出力、メンバー招待・ロール変更ができます。
member	プロジェクトメンバー	該当プロジェクト	担当プロジェクトの FAQ 編集、問い合わせ対応、ログ確認、データ出力ができます。

オーナーの project_users 行: オーナーはプロジェクト作成時に **project_users(role='admin', valid=1)** 行が自動 INSERT され、当該プロジェクトの明示的なプロジェクト管理者として行を保持する。認可上は Principal 構築時の **isOwner=true** 判定 (**contract_owners** 行存在) で **bypass** が優先され、**project_users** 行は critical 通知の宛先解決と画面表示の事実情報として参照される (詳細は 08_認証・認可設計.md § 6.1)。

1.3.2 3.2 ロール × 主管 SCR / FR 対応

ロール	主な操作対象 SCR / FR
オーナー	全 SCR、FR-015a / FR-015c / FR-030 / FR-030a / FR-030b / FR-115~127(課金) / FR-189(退会) / FR-193(API キー) / 規約

ロール	主な操作対象 SCR / FR
admin(プロジェクト管理者)	SCR-011 / 012 / 013 / 015(該当プロジェクト範囲) / SCR-017 / SCR-017-M1(操作者が admin のプロジェクト範囲) / 選択中プロジェクト詳細 / FR-015 / FR-016 / FR-018a~c / FR-040~046 / FR-070~079 / FR-086 / NFR-602 系列
member	SCR-001(ダッシュボード) / SCR-011 / 012 / 013 / 015(該当プロジェクト範囲) / FR-040~046 / FR-070~079 / FR-086(返信のみ)
招待トークン保有者(未認証)	SCR-031 メンバーアカウント有効化のみ (access_tokens.purpose='activation' 有効時のみ到達可能) / FR-016 / FR-016a / FR-016d / FR-016e。本画面以外には到達不可、有効化完了後は SCR-001 ログインへ遷移して通常 Principal が構築される
連絡先確認トークン保有者(未認証)	SCR-032 プロジェクト連絡先メール確認完了のみ (access_tokens.purpose='contact_verify' 有効時のみ到達可能) / FR-033a。アカウント作成は不要、第三者の共有メールアドレスでも本フローを進められる。確認完了後は静的ランディングに留まる

1.3.3 3.3 オーナー専有機能 (プロジェクト別ロールでは付与不可)

- ・プロジェクトの作成・編集 (SCR-010 / SCR-010-M1、許可ドメイン等のプロジェクト設定全般を含む)
- ・プロジェクトの削除 (SCR-026 のみに動線集約、DELETE /projects/{id})—— 削除時の挙動は論理削除 (projects.status='deleted' + valid=0) + 当該プロジェクトの project_users 全行 valid=0 + 他 PJ 割当が無くなった (非オーナー) メンバーの users.valid=0 論理削除 + セッション失効
- ・課金 (SCR-015 の月次予算変更 / 支払い方法変更)
- ・退会 (SCR-024)
- ・規約再同意 (SCR-025 の同意 / 不同意)
- ・メンバーアカウント削除 (DELETE /projects/{id}/members/{accountId}、アカウント全体論理削除)—— オーナー操作時は全メンバー削除可、プロジェクト管理者 (オーナー以外) 操作時は当該プロジェクトの member のみ削除可 (他 admin は member 在籍中削除不可)。詳細は FR-019 / FR-019a / FR-019b を正本とする
- ・契約ホーム閲覧 / OnboardingChecklist 操作 (SCR-026 全体、FR-326)—— プロジェクト管理者 / メンバーは契約ワークスペース自体が WorkspaceSwitcher に出現しないため到達不可。URL 直叩き (/owner/*) 時は 403 + 既定ワークスペースヘリダイレクト

UI 上は非表示 + API は 403(E-AUTHZ-OWNER-ONLY)。

1.4 4. 画面別権限マトリクス

凡例: ○ = 常時可、△ = 「緊急時のみ可」 (§9 参照)、自分のみ = 再入室トークンで特定された自分のチャット部屋のみ、× = 不可

プロジェクト管理者 / メンバー列は「該当プロジェクト割当ありかつそのロール保持時」の挙動を表す。

service_operator 列の注記: メイン側 users には service_operator 行を持たないが、本マトリクスの service_operator 列は「運営者が別 D1 から IF 経由でメイン API を呼び出す際の認可要件」を表現する。認可コンテキストは API ゲートウェイで構築された Principal の actor_role='service_operator' として渡される (audit_logs.actor_role でも同名で記録される)。

操作分類	オーナー	プロジェクト管理者 (該当 PJ)	メンバー (該当 PJ)	end	service_operator
ダッシュボード (自分の通知・お知らせ受信箱)	○	○	○	×	×
ダッシュボード表示モード切替 (オーナー表示 / プロジェクト表示)	○	×	×	×	×
契約ホーム閲覧 (SCR-026)	○(専有)	×	×	×	×
初回セットアップガイド (SCR-026 OnboardingChecklist、FR-326)	○(専有)	×	×	×	×
初回セットアップガイドの手動再表示 (ヘッダ「？」メニュー、FR-135h)	○(専有)	×	×	×	×
ダッシュボード KPI のクリックドリルダウン (FR-135e)	○	○(該当 PJ 範囲)	○(該当 PJ 範囲)	×	×

操作分類	オーナー	プロジェクト管理者 (該当PJ)	メンバー (該当PJ)	end	service_operator
契約ステータス帯 / AI コスト消化率 / 次回請求の閲覧 (SCR-026 § StatusBar)	○(専有)	×	×	×	×
FAQ 登録・編集・公開	○	○	○	×	△(運営者復元時のみ)
プロジェクト作成・編集・削除	○(専有)	×	×	×	△(運営者復元時のみ)
プロジェクト詳細閲覧 (選択中 PJ の基本情報)	○	○	○	×	×
メンバー招待・該当 PJ 離脱・該当 PJ 内ロール変更	○	○	×	×	×
メンバーアカウント 論理削除 (オーナー)	○(オーナー自身を除く全メンバー)	×	×	×	×
メンバーアカウント 論理削除 (プロジェクト管理者)	○(自動 admin)	○(当該 PJ の member のみ。他 admin は member 在籍中不可)	×	×	×
未解決質問閲覧・対応・担当割当	○	○	○	×	△(障害調査時のみ)
個別チャット返信	○	○	○	自分のみ	×
個別チャット閲覧	○	○	○	自分のみ	△(障害調査時のみ)
質問ログ閲覧	○	○	○	×	×
監査ログ閲覧 (自契約)	○	○	○	×	○(全契約)
課金情報閲覧・変更	○(専有)	×	×	×	△(訂正・サポート時のみ)
退会申請・解約	○(専有)	×	×	×	×
規約再同意の承諾	○(専有)	×	×	×	×
データエクスポート	○	○	○	×	×
契約無効化 (サスペンション)	×	×	×	×	○
契約物理削除	×	×	×	×	○(退会後の自動バッチ)
プロンプトテンプレート編集	×	×	×	×	○(運営者のみ)
案件「終了」確定	○	○	○	×	×
案件「解決済み」	○	○	○	×	×
お知らせ閲覧 (自契約)	○	○	○	×	△(運用調査時のみ)
お知らせ既読化	○	○	○	×	×
お知らせ作成・配信	×	×	×	×	○
critical 通知 (ロックアウト 等) 受信	○	○	×	×	×
メンバーアカウント有効化 (SCR-031、招待トークン保有者のみ)	-	-	-	×	×
プロジェクト連絡先メール確認 (SCR-032、連絡先確認トークン保有者のみ)	-	-	-	×	×

SCR-031 メンバーアカウント有効化ページ: 上記表外の特別画面。Cookie セッション認証を持たない未認証ユーザーが招待リンク経由でアクセスする。認可条件は `access_tokens.purpose='activation'` の有効トークン (期限内 + 未使用) を保持していることのみで、ロール列 (オーナー / プロジェクト管理者 / メンバー) は適用されない。トークン認証 Principal(`user_id + access_tokens.meta.invitedProjectId / invitedRole`) を構築し、本画面以外でこの Principal は使用しない。詳細は 08_ 認証・認可設計.md § 3.4 / § 5.1 を参照。

SCR-032 プロジェクト連絡先メール確認完了ページ: 同様に未認証ユーザーがプロジェクト連絡先確認トークン経由でアクセスする画面。`access_tokens.purpose='contact_verify'` の有効トークン保持が唯

一の認可条件で、連絡先メール所有者はアカウントを持つ必要がない(第三者の共有メールアドレスでも構わない)。トークン認証 Principal(`access_tokens.meta.projectId` のみ、`user_id` は持たない) を構築し、`projects.contact_email_verified_at` の単純な書き込みのみを行う。本画面以外でこの Principal は使用しない。詳細は 08_ 認証・認可設計.md §5.1 を参照。

1.5 5. 機能別権限

機能 ID	機能名	必要ロール	オーナー	制限事項
F-AUTH-*	認証	不要	○	-
F-PRJ-*	プロジェクト管理 (作成・編集・削除)	オーナー専有	○	削除は再認証必須
F-FAQ-*	FAQ 管理	member+(該当 PJ)	○	公開ガード (draft → published 直接遷移禁止)
F-INQ-*	未解決質問	member+(該当 PJ)	○	状況 (open / closed) は SCR-011 詳細画面からの手動操作のみで切替。FAQ 下書き保存・FAQ 公開・個別チャットの操作は連動しない (FR-079)
F-CHAT-*	個別チャット	member+(該当 PJ)	○	投稿・既読・担当割当のみ。部屋状態と FAQ 登録操作は持たない
F-WIDG-*	ウィジェット設定 (プロジェクト単位)	admin+(該当 PJ)	○	公開キー再発行は L3(再認証必須)。member は閲覧 + 埋め込みコードのコピーのみ可。配置はプロジェクトワークスペース (SCR-014)
F-BILL-*	課金	オーナー専有	○	月次予算変更は再認証必須
F-USER-*	ユーザー管理 (招待・ロール変更・アカウント削除)	admin+(該当 PJ) / オーナー (自動 admin)	○	招待 / ロール変更 / アカウント削除 / 招待再送は再認証必須。削除はアカウント全体論理削除 (users.valid=0)
F-ACC-*	アカウント設定 / 退会	オーナー専有	○	退会は再認証必須
F-NOTIF-*	お知らせ	全 admin	○	既読化のみ
F-LEGAL-*	規約 / 同意	オーナー専有 (同意) / 全ユーザー (閲覧)	○	-

「member+(該当 PJ)」は該当プロジェクトに対するロールが **member** または **admin** であることを示す (オーナーは bypass)。「admin+(該当 PJ)」は該当プロジェクトに対するロールが **admin** のみを示す。

1.6 6. API 別権限

03_API 設計書.md を正本とする。主要 API:

API	メソッド	必要ロール	オーナー専有	再認証	関連エラー ID
POST /auth/login	POST	不要	-	-	E-AUTH-*
POST /projects	POST	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
PATCH /projects/{id}	PATCH	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY

API	メソッド	必要ロール	オーナー 専有	再認証	関連エラー ID
DELETE /projects/{id}	DELETE	オーナー専有	○	○	E-AUTHZ-OWNER-ONLY
POST /faqs / PATCH / DELETE	*	member+(該当PJ)	-	DELETEのみ○	-
POST /faqs/{id}/publish	POST	member+(該当PJ)	-	-	E-BIZ-FAQ-PUBLISH(公開ガード)
PATCH /inquiries/{id}	PATCH	member+(該当PJ)	-	-	担当者変更および status の手動切替 (open / closed) を許可
POST /chat-rooms/{id}/messages	POST	member+(該当PJ)	-	-	投稿文字数・頻度制限
GET /usage / GET /billing/invoices	GET	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
PATCH /billing/monthly-budget-limit	PATCH	オーナー専有	○	○	-
POST /projects/{id}/members	POST	admin+(該当PJ)/ オーナー	-	○	E-AUTHZ-FORBIDDEN / AL-READY_EXISTS_IN_PROJECT
PATCH /projects/{id}/members/{account_id}	PATCH	admin+(該当PJ)/ オーナー	-	○	E-AUTHZ-LAST-ADMIN-PROTECTED(該当PJの最後の admin 降格時)
DELETE /projects/{id}/members/{user_id}	DELETE	admin+(該当PJ)/ オーナー	-	○	E-AUTHZ-OWNER-PROTECTED / E-AUTHZ-SELF-MUTATION / E-AUTHZ-ADMIN-DELETE-PROTECTED / E-BIZ-ACCOUNT-INACTIVE(アカウント全体論理削除 (users.valid=0)。詳細は FR-019)
POST /withdrawal-requests	POST	オーナー専有	○	○	-
POST /terms/agree	POST	オーナー専有 (承諾)	○	-	-

1.7 7. 契約別利用制限 / 運営者上書き

1.7.1 7.1 単一プランの利用上限 (11_課金請求設計書.md §3 参照)

MVP は単一プラン (完全従量課金 + 月次無料枠 + 14 日トライアル)。プラン階層による差別化はない。利用上限は **owner_quota_overrides.resource_kind** で統一実装される (テーブル定義書 04 § 3.25 参照)。

resource_kind	用途	主管 SCR(運営者)
widget_ask_per_min	ウィジェット質問レート	SCR-093
widget_inquiry_per_min	ウィジェット未解決質問送信レート	SCR-093
widget_chat_per_min	ウィジェットチャット投稿レート	SCR-093
email_per_hour	メール送信レート	SCR-093
admin_api_per_min	管理 API レート	SCR-093

1.7.2 7.2 80/100/125% 三段階アクション (11_課金請求設計書.md §8 の参照)

データ種別	80%	100%	125%
質問数	inbox 通知 (normal)	inbox + email(high)、拒否しない (事後課金)	翌1時間レート制限 1/2 + 運営者エスカレーション
FAQ 件数	inbox 通知	新規登録拒否 (編集可)	+ 運営者エスカレーション
個別チャット部屋数	inbox 通知	新規作成拒否 (返信可)	+ 運営者エスカレーション

詳細は 11_課金請求設計書.md §8 を正本とする。

1.8 8. 権限不足・契約上書き時の動作

ケース	システム動作	画面表示	メッセージ ID	関連エラー ID
ロール不足 (member で admin 限定操作を試行)	403 統一	「この操作を行う権限がありません。必要な場合は、契約オーナーまたはプロジェクト管理者に依頼してください」	MSG-COMMON-AUTHZ-403	E-AUTHZ-FORBIDDEN
オーナー境界違反 (他契約のリソース参照)	404 偽装 (403 だと相手契約の存在が漏れる)	「指定された情報は見つかりませんでした。URL や選択中のワークスペースを確認してください」	MSG-COMMON-NOT-FOUND	E-AUTHZ-OWNER-BOUNDARY
プロジェクト割当不足 (project_users に行なし)	404 偽装	「指定された情報は見つかりませんでした。URL や選択中のワークスペースを確認してください」	MSG-COMMON-NOT-FOUND	E-AUTHZ-PROJECT-DENIED
オーナー専有機能 (contract_owners 行を持たないユーザーがアクセス)	403 + 専用コード、UI 非表示	「この機能は契約オーナーのみ利用できます。必要な場合は契約オーナーに依頼してください」	MSG-COMMON-OWNER-ONLY	E-AUTHZ-OWNER-ONLY
オーナー保護違反 (オーナー停止 / 削除)	403	「契約オーナーは停止・削除できません。変更が必要な場合はサポートへお問い合わせください」	MSG-COMMON-OWNER-PROTECTED	E-AUTHZ-OWNER-PROTECTED
自己操作不可 (自分が admin を持つ最後のプロジェクトで自身を降格 / 割当解除)	403、UI 非活性	「このプロジェクトの最後の管理者です。先に別の管理者を追加してください」	MSG-COMMON-SELF-MUTATION	E-AUTHZ-SELF-MUTATION
最後の管理者保護 (他者をプロジェクトの最後の admin から外す)	403	「このプロジェクトには管理者が最低 1 名必要です。先に別の管理者を追加してください」	MSG-COMMON-LAST-ADMIN	E-AUTHZ-LAST-ADMIN-PROTECTED
契約停止中 (contract_status=suspended)	403 + 専用コード、課金画面 / 退会画面 / データエクスポートのみ許可	サスペンション理由 + 再決済誘導	MSG-BILL-CONTRACT-SUSPENDED	E-BIZ-CONTRACT-SUSPENDED
月次無料枠 100% 超過 (質問数以外)	429 + Retry-After	「上限に到達しました」 + 課金ダッシュボード誘導	MSG-QUOTA-*	E-BIZ-QUOTA-EXCEEDED

詳細は [06_エラー設計書.md §5](#) を正本とする。

1.9 9. 緊急時のみ可操作 (§3.2.1-2 から移管)

1.9.1 9.1 「△ 緊急時のみ可」操作の発動条件

条件	実装方針 (メイン側)
1. サポートチケット ID 必須	連携 IF #4 / #5 / #6 / #12 のリクエスト JSON に ticket_id フィールドを必須化。メイン側で空文字検証 + 監査ログ記録
2. 運営者 2 名の承認 (自己承認不可)	顧客管理側で承認を取得し、結果を連携 IF 経由で伝搬。メイン側はメタフィールド approvals[] (承認者 2 名分) の検証 (承認者 ID が異なる、承認時刻が 24 時間以内、kid 検証) を実施
3. 管理者ユーザーへの即時通知	メイン側で inbox_messages レコードを生成 (category=system、importance=high) + メール送信を Queue 投入
4. 監査ログ必須記録	<resource>.<verb>.by_operator 形式の action コードで audit_logs に記録。retention_class=operator_high_priv (5 年保持)

1.9.2 9.2 緊急区分 × 検知ハンドラ × 承認 SLA

緊急区分	検知ハンドラ	承認 SLA	エスカレーション経路
重大障害	monitoring:main_outage 監視 / 連携 IF #2 ヘルスチェック (5s × 3 連続失敗)	15 分以内に 2 名承認	RB-021(メイン障害時の運営者側縮退運転) と連動
全員ロックアウト	audit_logs(auth.locked) 集約検知 (該当契約内全 admin が auth.locked 状態)	30 分以内に CS マネージャーへ通報	サポート窓口経由でオーナーと連絡、紙ベース回復コード (RB-014) も可
セキュリティインシデント	NFR-602c 監査ログ完全性検証バッチ / SIEM / 不正アクセス検知 (FR-178)	即時 PagerDuty 起動	セキュリティ責任者 → CTO → 運営本部
法令対応	(運用側で個別判断)	個別判断	法務 → CTO

1.10 10. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------